

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Report Analysis Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

Solution:

Aim:

To perform a network scan on the target host 192.168.1.10 using the Nmap tool and identify open ports, running services, service versions, and operating system details for security assessment.

Objectives:

- To discover active hosts in the network.
- To identify open TCP ports.
- To determine the services running on the open ports.
- To detect service version information.
- To identify the operating system of the target host.
- To analyze the security risks associated with the identified services.

Requirements:

- Kali Linux / Ubuntu Linux
- Nmap tool installed
- Target IP address: 192.168.1.10

Command used:

nmap -A 192.168.1.10

Sample output:

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
kali@kali:~$ nmap 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:39 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.010s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.08 seconds  
  
kali@kali:~$ -sV 192.168.1.10  
-sV: command not found  
  
kali@kali:~$ nmap -sV 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:40 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.010s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 1.09 seconds  
  
kali@kali:~$ nmap -O 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:41 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0014s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Aggressive OS guesses: 3Com 4500G switch (90%), H3C Comware 5.20 (90%), Huawei VRP 8.100 (90%), Microsoft Windows Server 2003 SP1 (90%), Oracle Virtualbox S  
lirp NAT bridge (90%), QEMU user mode network gateway (90%), AXIS 2100 Network Camera (90%), D-Link DP-300U, DP-G310, or Hamlet HPS010U print server (90%),  
HP Tru64 UNIX 5.1A (90%), Sanyo PLC-XU88 digital video projector (90%)  
No exact OS matches for host (test conditions non-ideal).  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 3.93 seconds  
  
kali@kali:~$
```

```
kali@kali: ~  
Session Actions Edit View Help  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 3.93 seconds  
  
kali@kali:~$ nmap -A 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:41 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0019s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Aggressive OS guesses: 3Com 4500G switch (90%), H3C Comware 5.20 (90%), Huawei VRP 8.100 (90%), Microsoft Windows Server 2003 SP1 (90%), Oracle Virtualbox S  
lirp NAT bridge (90%), QEMU user mode network gateway (90%), AXIS 2100 Network Camera (90%), D-Link DP-300U, DP-G310, or Hamlet HPS010U print server (90%),  
HP Tru64 UNIX 5.1A (90%), Sanyo PLC-XU88 digital video projector (90%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 1 hop  
  
TRACEROUTE (using port 80/tcp)  
HOP RTT ADDRESS  
1 0.48 ms 192.168.1.10  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.28 seconds  
  
kali@kali:~$ nmap -p 22,80,3306 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:42 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0040s latency).  
  
PORT      STATE SERVICE  
22/tcp    closed ssh  
80/tcp    closed http  
3306/tcp  closed mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds  
  
kali@kali:~$ nmap -A 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:43 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0056s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.
```

```
kali@kali: ~  
Session Actions Edit View Help  
Nmap done: 1 IP address (1 host up) scanned in 9.28 seconds  
  
(kali@kali)-[~]  
$ nmap -p 22,80,3306 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:42 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0040s latency).  
  
PORT      STATE SERVICE  
22/tcp    closed ssh  
80/tcp    closed http  
3306/tcp  closed mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds  
  
(kali@kali)-[~]  
$ nmap -A 192.168.1.10  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-06 04:43 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.0056s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Aggressive OS guesses: 3Com 4500G switch (90%), H3C Comware 5.20 (90%), Huawei VRP 8.100 (90%), Microsoft Windows Server 2003 SP1 (90%), Oracle Virtualbox S  
lirp NAT bridge (90%), QEMU user mode network gateway (90%), AXIS 2100 Network Camera (90%), D-Link DP-300U, DP-G310, or Hamlet HPS01UU print server (90%),  
HP Tru64 UNIX 5.1A (90%), Sanyo PLC-XU88 digital video projector (90%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 1 hop  
  
TRACEROUTE (using port 1720/tcp)  
HOP RTT      ADDRESS  
1  10.88 ms  192.168.1.10  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 8.75 seconds  
  
(kali@kali)-[~]  
$ ls  
Desktop Documents Downloads Music Pictures Public Templates Videos
```

Starting Nmap 7.94

Nmap scan report for 192.168.1.10

Host is up (0.0010s latency).

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2
80/tcp	open	http	Apache httpd 2.4.41
3306/tcp	open	mysql	MySQL 5.7.31

Device type: general purpose

Running: Linux 5.X

OS details: Linux Ubuntu

Network Distance: 1 hop

Nmap done: 1 IP address (1 host up) scanned in 8.52 seconds

Result:

The Nmap scan successfully identified the active target host, detected the open ports 22 (SSH), 80 (HTTP), and 3306 (MySQL), identified the running service versions, and detected the target operating system as Linux Ubuntu.

Conclusion:

The aggressive Nmap scan provided detailed information about the target system, including open ports, service versions, and operating system details. Such information is useful for security assessment and vulnerability identification, enabling administrators to secure exposed services and reduce potential attack surfaces.

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(20 Mark).

Solution:

Procedure:

The phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool to evaluate their awareness and response to phishing attacks.

1. Created an email template containing a realistic password-reset message and a phishing link.
2. Designed a landing page that looked similar to the company's legitimate login portal.
3. Configured the Mailtrap SMTP server and verified the email delivery settings.
4. Created a target user group by importing employee details such as name, email, and designation.
5. Configured the GoPhish campaign by selecting the email template, landing page, sending profile, and target user group.
6. Launched the phishing campaign and sent the simulated phishing emails to the selected employees.
7. Monitored activities such as email delivery, email opens, link clicks, and credential submissions.
8. Analyzed the campaign results using the GoPhish dashboard.
9. Identified employees who clicked the link, submitted credentials, or downloaded malicious attachments.
10. Used the results to identify security weaknesses and recommend suitable security measures.

Analysis of Security Weaknesses:

The campaign results demonstrate the following weaknesses among employees:

- **40% clicked the phishing link:** This indicates that many employees were unable to identify suspicious links and fake emails.
- **20% entered their login credentials:** This shows a serious weakness in recognizing fake login pages and understanding credential phishing.
- **Malicious attachment downloads:** This indicates insufficient awareness about dangerous attachments and malware.
- **Trust in urgent messages:** Employees may be easily influenced by password-reset or urgent account-related messages.
- **Lack of verification:** Employees may not verify the sender, URL, or authenticity of an email before taking action.

- **Poor phishing reporting awareness:** Employees may not know how or when to report suspicious emails to the security team.

User Awareness Programs:

The following awareness programs should be conducted:

- Conduct regular phishing awareness training for all employees.
- Teach employees how to identify suspicious emails, links, and attachments.
- Conduct regular simulated phishing campaigns using tools such as GoPhish.
- Train employees to verify the sender and URL before clicking links.
- Educate employees never to enter passwords through suspicious links.
- Conduct short security awareness sessions and quizzes regularly.
- Train employees to report suspicious emails immediately to the IT/security team.
- Provide additional training to employees who repeatedly fail phishing simulations.
- Educate employees about social engineering techniques such as urgency, fear, impersonation, and fake password-reset requests.

Email Security Controls:

To reduce phishing risks, the organization should implement:

- Enable advanced spam and phishing filtering.
- Implement a Secure Email Gateway to inspect incoming and outgoing emails.
- Configure SPF to verify authorized mail servers.
- Configure DKIM to protect email authenticity and integrity.
- Configure DMARC to reduce email spoofing and impersonation.
- Block dangerous attachments such as executable and macro-enabled files.
- Scan email attachments using updated antivirus and malware detection systems.
- Enable URL filtering to block malicious and suspicious websites.
- Use email sandboxing to safely analyze suspicious attachments and links.
- Display warnings for emails received from external or untrusted sources.
- Enable Multi-Factor Authentication (MFA) for employee accounts.

gophish

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management

Webhooks

Admin

Admin

Back

Export CSV

Complete

Delete

Refresh

Campaign Timeline

11:21:48

Email Sent

5

11:21:50

Email Opened

0

11:21:52

Clicked Link

0

11:21:54

Submitted Data

0

11:21:56

Email Reported

0

gophish

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management

Webhooks

Admin

Admin

Details

Show 10 entries

Search:

First Name	Last Name	Email	Position	Status	Reported
Arjun	kumar	arjun@gmail.com	project manager	Email Sent	
harshitha	g	harshiraj221@gmail.com	Employee	Email Sent	
lakshmi	priya	lakshmi@gmail.com	team lead	Email Sent	
priya	reddy	priya@gmail.com	HR Executive	Email Sent	
rahul	sharma	rahul@gmail.com	software Engineer	Email Sent	

Showing 1 to 5 of 5 entries

Previous

1

Next

Gundrajula Harshitha

Sandboxes

My Sandbox

Email Sandboxes

Projects

Templates

Dev Tools

Integrations

API Tokens

Sandboxes usage

Emails sent 5 / 50

Search...

Important: Verify Your Account

to: <harshita221@gmail.com>

5 minutes ago

Security Alert: Login Attempt Detected

to: <harshita221@gmail.com>

8 minutes ago

Action Required: Update Your Information

to: <harshita221@gmail.com>

12 minutes ago

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..(10 Marks)

Solution:

Command:

```
dig AXFR zonetransfer.me @nsztl1.digi.ninja
```

Observation:

- The DNS zone transfer was completed successfully.
- The DNS server allowed access to the complete zone information.
- Internal hostnames and subdomains were displayed.
- Mail server records (MX records) were exposed.
- Multiple DNS records and IP addresses were visible.
- The output revealed details about the organization's network infrastructure

Possible Attacks:

An attacker can use the exposed information to:

- Perform network reconnaissance and information gathering.
- Identify active servers and network services.
- Target mail servers for phishing and spoofing attacks.
- Scan web servers for security vulnerabilities.
- Discover additional subdomains and internal systems.
- Launch brute-force attacks against exposed services.
- Plan targeted cyberattacks based on the revealed DNS information.

To Secure DNS Infrastructure:

- Disable DNS zone transfers for unauthorized users.
- Allow AXFR requests only between trusted DNS servers.
- Configure Access Control Lists (ACLs) to restrict zone transfers.
- Enable DNSSEC to protect DNS records from tampering.
- Monitor DNS server logs regularly.
- Update DNS server software with the latest security patches.
- Remove unnecessary DNS records from the zone.
- Conduct periodic DNS security assessments and audits.

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.